PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

# Menaces sur les téléphones mobiles

03-1200 CERT-FR - Téléphones mobiles, état de la menace et recommandations — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

**À RETENIR**

1. La surface d'attaque inclut les interfaces sans fil, les applications, le système d'exploitation et les composants matériels.
2. Les entreprises de LIOP vendent des capacités d'intrusion aux États, ce qui dissémine des outils d'espionnage avancés.
3. Le processus de Pall Mall vise à produire un code de bonnes pratiques pour les États afin de lutter contre l'usage irresponsable des outils offensifs commerciaux.

## Cibles et menaces

| Notion | À retenir |
|---|---|
| Equipements omniprésents | Surface d'attaque : **interfaces sans fil**, **applications**, **système d'exploitation** et **composants matériels**. Furtivité et **absence de solutions de détection** compliquent les investigations. |
| Personnes visées | Logiciels espions : **hautes autorités**, élus, dirigeants stratégiques, **avocats**, **journalistes**, militants, dissidents et **proches**. Toute la population : cybercriminels (vol d'identifiants, ingénierie sociale). |

## Constat de l'ANSSI

**3 ans**

Période durant laquelle l'ANSSI a traité de multiples compromissions de téléphones de hauts responsables publics et de dirigeants d'entreprises stratégiques.

Le plus souvent sur leurs **téléphones personnels**.

## Vecteurs d'attaque mobiles

| Notion | À retenir |
|---|---|
| Interfaces sans fil | Interception **passive/active** et **altération** de données. **2G** (SMS en clair, pas d'authentification antennes) vulnérable aux **IMSI catchers** ; décommissionnement France **2026**. Wi-Fi, Bluetooth, NFC vulnérables. |
| Système et applications | Chaînes **zéro-clic** ciblant les **messageries préinstallées**. Exemples : **Pegasus**, **Predator**, **Graphite** ou opération **Triangulation**. |

## Acteurs et alertes

| Notion | À retenir |
|---|---|
| États et entreprises privées | États : capacités **internes** ou via l'**industrie de défense**. Entreprises de **LIOP** (**NSO Group**, **Intellexa**, **Paragon**) : vendent aux États qui n'en disposent pas ou veulent **compliquer l'attribution** → **dissémination**. **Imputation** = lien avec un mode opératoire ; **attribution** = commanditaire politique. |
| Processus de Pall Mall | Lancé en **novembre 2023**, formalisé à **Londres** en **février 2024** : produit un **code de bonnes pratiques** pour les États. |
| En cas d'alerte | Si un éditeur signale une compromission possible : **ne pas manipuler** le téléphone, contacter le **CERT-FR** (courriel ou **3218**). |

## Recommandations de sécurité

| Notion | À retenir |
|---|---|
| Réduire la surface d'attaque | **Désactiver** Wi-Fi, Bluetooth, NFC, messageries inutilisées et **MMS automatiques**. Utiliser **VPN maîtrisé** ou messageries **chiffrées de bout en bout**. Mode **Isolement** (iOS) ou **protection avancée** (Android). |
| Protéger l'authentification et le terminal | **Code PIN** SIM personnalisé, **applications d'authentification** plutôt que SMS. Mises à jour **sans reporter le redémarrage**. Éteindre/rallumer régulièrement (supprime les **implants non persistants**, sans empêcher une réinfection ; certains espions **simulent** un redémarrage). Pas de liens, QR codes ou équipements inconnus. |

## Pièges et confusions

- ⚠ Croire que les attaques zéro-clic nécessitent une action de la victime
- ⚠ Confondre l'imputation (mode opératoire) et l'attribution (commanditaire politique)
- ⚠ Penser qu'un arrêt complet du téléphone empêche une réinfection après la suppression d'un implant non persistant
- ⚠ Oublier que les téléphones personnels des responsables sont souvent la porte d'entrée

## Sigles et définitions

| | |
|---|---|
| **Logiciel espion** | Code malveillant collectant communications, localisation et données à l'insu de la victime |
| **Attaque zéro-clic** | Exploitation d'une chaîne de vulnérabilités jour-zéro sans interaction de la cible |
| **Implant non persistant** | Code qui ne survit pas à l'arrêt complet du téléphone |
| **LIOP** | Lutte informatique offensive privée désignant les entreprises vendant des capacités d'intrusion |
| **AITM** | Adversary-in-the-middle plaçant l'attaquant entre deux équipements pour intercepter ou modifier les échanges |
| **IMSI catcher** | Dispositif imitant une antenne-relais pour capter l'identité, les communications et la localisation en 2G, 3G et 4G |

## Auto-test

1. Quelle est la durée durant laquelle l'ANSSI a traité de multiples compromissions de téléphones de hauts responsables ?
2. Quels sont les exemples de chaînes zéro-clic cités ?
3. Que permet de supprimer un redémarrage régulier ?
4. En quelle année le décommissionnement de la 2G est-il prévu en France ?
5. Quelles entreprises sont citées comme acteurs de la LIOP ?

Réponses : **1.** 3 ans · **2.** Pegasus, Predator, Graphite ou opération Triangulation · **3.** Les implants non persistants · **4.** 2026 · **5.** NSO Group, Intellexa, Paragon

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.